📋 Báo cáo API Backend — DevJobs

Tài liệu mô tả toàn bộ REST API của nền tảng tuyển dụng IT DevJobs

ASP.NET Core 8.0	Entity Framework Core	SQL Server	JWT Auth	Version 1.0

1. Giới thiệu dự án

DevJobs là nền tảng tuyển dụng IT cho phép ứng viên tìm kiếm việc làm, nhà tuyển dụng đăng tin và quản trị viên kiểm soát toàn bộ hệ thống. Backend được xây dựng theo kiến trúc **REST API**, hoàn toàn tách biệt khỏi frontend.

ASP.NET Core 8.0 · Entity Framework Core 8 · SQL Server · BCrypt.Net-Next · JWT Bearer Token · Swagger / OpenAPI · Google OAuth 2.0

Phân quyền người dùng (3 Role)

ROLE	TÊN GỌI	QUYỀN TRUY CẬP
candidate	Ứng viên	Tìm việc, nộp hồ sơ, quản lý hồ sơ cá nhân
recruiter	Nhà tuyển dụng	Đăng tin, quản lý tin, xem & xử lý hồ sơ ứng viên
admin	Quản trị viên	Duyệt tin, quản lý tất cả người dùng, xem thống kê

2. Kiến trúc hệ thống

```
┌──────────────────────────────────────┐
│ CLIENT (Trình duyệt)                 │
│ React + Vite — port 5173             │
```

```
└──────────────────────┬──────────────────────────────────┘
                       │ HTTP / JSON
                       │ Authorization: Bearer <JWT Token>
┌──────────────────────▼──────────────────────────────────┐
│ REST API (ASP.NET Core 8.0) │
│ http://localhost:5050/api │
│ Swagger UI: http://localhost:5050/swagger │
└──────────────────────┬──────────────────────────────────┘
                       │ Entity Framework Core
┌──────────────────────▼──────────────────────────────────┐
│ SQL Server Database │
│ Users · Companies · Jobs · Applications │
└──────────────────────────────────────────────────────────┘
```

> 💡 **Luồng xác thực:** Client gọi `POST /api/auth/login` → nhận JWT Token → gửi kèm trong header `Authorization: Bearer {token}` cho các request tiếp theo.

3. Cơ sở dữ liệu

BẢNG	MÔ TẢ	QUAN HỆ CHÍNH
Users	Tài khoản người dùng (3 role)	1–n với Companies, Applications
Companies	Thông tin công ty của nhà tuyển dụng	1–n với Jobs
Jobs	Tin tuyển dụng	n–n với Skills qua JobSkills; 1–n với Applications
Applications	Hồ sơ ứng tuyển	n–1 với Users (candidate) và Jobs
Skills	Danh mục kỹ năng (React, Java...)	n–n với Jobs
JobSkills	Bảng trung gian Job–Skill	FK: JobId, SkillId

Các cột quan trọng — Bảng Users

CỘT	KIỂU	MÔ TẢ
user_id	int PK	Khóa chính tự tăng
email	nvarchar(100)	Email đăng nhập (unique)
password_hash	nvarchar	Mật khẩu hash BCrypt
full_name	nvarchar(100)	Tên hiển thị (Unicode)
role	varchar(20)	candidate / recruiter / admin
status	varchar(20)	active / suspended
cv_url	nvarchar	Đường dẫn CV

4. Bảo mật & Xác thực

🔐 JWT Bearer Token

Mỗi token gồm 3 phần: **Header** (thuật toán HS256) · **Payload** (UserId, Role, CompanyId) · **Signature**. Token có thời hạn **7 ngày**.

```
// Cấu hình JWT trong Program.cs
builder.Services.AddAuthentication(JwtBearerDefaults.AuthenticationScheme)
    .AddJwtBearer(options => {
        options.TokenValidationParameters = new TokenValidationParameters {
            ValidateIssuerSigningKey = true,
            IssuerSigningKey = new SymmetricSecurityKey(key),
            ValidateLifetime = true
        };
    });
```

🔑 BCrypt Password Hashing

Mật khẩu **không bao giờ lưu dạng plaintext**. Dùng BCrypt với cost factor mặc định (10 rounds). Không thể giải mã ngược.

```
// Hash khi đăng ký
user.PasswordHash = BCrypt.Net.BCrypt.HashPassword(req.Password);

// Verify khi đăng nhập
bool valid = BCrypt.Net.BCrypt.Verify(req.Password, user.PasswordHash);
```

🛡️ Phân quyền theo Role

DECORATOR	Ý NGHĨA
`[AllowAnonymous]`	Không cần đăng nhập
`[Authorize]`	Phải đăng nhập (bất kỳ role)
`[Authorize(Roles = "candidate")]`	Chỉ Ứng viên
`[Authorize(Roles = "recruiter")]`	Chỉ Nhà tuyển dụng
`[Authorize(Roles = "admin")]`	Chỉ Admin

🌐 CORS Policy

Chỉ cho phép request từ origin được whitelist. Cấu hình trong `Program.cs`:

```
builder.Services.AddCors(opt => opt.AddPolicy("AllowFrontend", p =>
    p.WithOrigins("http://localhost:5173", "http://localhost:5174")
     .AllowAnyMethod().AllowAnyHeader()));
```

5. API Endpoints

🔐 AuthController Base: /api/auth

METHOD	ENDPOINT	AUTH	MÔ TẢ
POST	/api/auth/login	Public	Đăng nhập bằng email/password, trả về JWT token
POST	/api/auth/register	Public	Đăng ký tài khoản mới (candidate hoặc recruiter)
POST	/api/auth/google	Public	Đăng nhập bằng Google OAuth — xác minh ID token với Google, tự tạo tài khoản nếu mới

💼 JobsController Base: /api/jobs

METHOD	ENDPOINT	AUTH	MÔ TẢ
GET	/api/jobs	Public	Danh sách tin tuyển dụng (hỗ trợ filter: keyword, location, jobType, salary, skill, phân trang)
GET	/api/jobs/{id}	Public	Chi tiết một tin tuyển dụng
GET	/api/jobs/my	Recruiter	Danh sách tin đã đăng của nhà tuyển dụng hiện tại
GET	/api/jobs/pending	Admin	Danh sách tin đang chờ duyệt
POST	/api/jobs	Recruiter	Đăng tin tuyển dụng mới (trạng thái pending, chờ admin duyệt)
PUT	/api/jobs/{id}	Recruiter	Cập nhật thông tin tin tuyển dụng
PUT	/api/jobs/{id}/approve	Admin	Phê duyệt tin (chuyển status → active)
PUT	/api/jobs/{id}/reject	Admin	Từ chối tin (chuyển status → rejected)
PUT	/api/jobs/{id}/close	Recruiter	Đóng tin tuyển dụng (chuyển status → closed)
PUT	/api/jobs/{id}/renew	Recruiter	Gia hạn tin thêm 30 ngày (chuyển status → active)

📄 ApplicationsController Base: /api/applications

METHOD	ENDPOINT	AUTH	MÔ TẢ
POST	/api/applications	Candidate	Nộp hồ sơ ứng tuyển (kiểm tra đã ứng tuyển chưa, job có active không)
GET	/api/applications/my-applications	Candidate	Lịch sử ứng tuyển của tôi
GET	/api/applications/job/{jobId}	Recruiter	Danh sách ứng viên của một tin (chỉ chủ tin mới xem được)
PUT	/api/applications/{id}/status	Recruiter	Cập nhật trạng thái hồ sơ: pending → shortlisted → interview → accepted / rejected

👤 UsersController Base: /api/users

METHOD	ENDPOINT	AUTH	MÔ TẢ
GET	/api/users/me	Bất kỳ	Thông tin tài khoản đang đăng nhập (kèm companyId nếu là recruiter)
PUT	/api/users/me	Candidate	Cập nhật hồ sơ cá nhân (tên, điện thoại, CV URL, kỹ năng)
GET	/api/users	Admin	Danh sách toàn bộ người dùng (trừ admin)
PUT	/api/users/{id}/suspend	Admin	Khóa / Mở khoá tài khoản người dùng
DELETE	/api/users/{id}	Admin	Xoá tài khoản người dùng (không thể xoá admin)

🏢 CompaniesController Base: /api/companies

METHOD	ENDPOINT	AUTH	MÔ TẢ
GET	/api/companies/{id}	Public	Thông tin công ty theo ID (kèm số tin đang tuyển)
POST	/api/companies	Recruiter	Tạo công ty mới (recruiter chưa có công ty)
PUT	/api/companies/my	Recruiter	Cập nhật thông tin công ty của recruiter hiện tại

🔧 Skills & Admin /api/skills · /api/admin

METHOD	ENDPOINT	AUTH	MÔ TẢ
GET	/api/skills	Public	Danh sách tất cả kỹ năng (React, Java, Python...)
GET	/api/admin/stats	Admin	Thống kê tổng quan: số users, jobs, applications, companies + hoạt động gần đây
POST	/api/seed	Public	Tạo dữ liệu mẫu lần 2 (chạy 1 lần)
POST	/api/seed/fix-unicode	Public	Sửa dữ liệu vị trí tiếng Việt bị lỗi encoding
POST	/api/seed/fix-names	Public	Sửa tên người dùng tiếng Việt bị lỗi encoding

6. Ví dụ Request / Response

📌 Ví dụ 1: Đăng nhập

POST `/api/auth/login`

Request Body:

```
{
  "email": "candidate@devjobs.vn",
  "password": "123456"
}
```

Response 200:

```
{
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
  "user": {
    "userId": 1,
    "email": "candidate@devjobs.vn",
    "fullName": "Nguyễn Văn A",
    "role": "candidate",
    "status": "active"
  }
}
```

📌 Ví dụ 2: Đăng tin tuyển dụng

POST `/api/jobs` Recruiter — Header: `Authorization: Bearer <token>`

Request Body:

```
{
  "title": "Senior React Developer",
  "description": "Phát triển ứng dụng web với React 18...",
  "requirements": "3+ năm kinh nghiệm React\nHiểu biết TypeScript",
  "salaryMin": 1500,
  "salaryMax": 2500,
  "location": "Hà Nội",
  "jobType": "full-time",
  "expiryDate": "2026-05-01",
  "skillIds": [1, 3]
}
```

Response 200:

```
{ "message": "Đăng tin thành công, chờ admin phê duyệt", "jobId": 5 }
```

📌 Ví dụ 3: Nộp hồ sơ ứng tuyển

POST `/api/applications` Candidate

Request Body:

```
{
  "jobId": 1,
  "cvUrl": "/uploads/cv_nguyen_van_a.pdf",
  "coverLetter": "Tôi có 3 năm kinh nghiệm React và rất mong muốn..."
}
```

Response 200:

```
{ "message": "Nộp hồ sơ thành công", "applicationId": 7 }
```

> ⚠️ Nếu ứng viên đã nộp hồ sơ trước đó → Response 400: "*Bạn đã ứng tuyển vị trí này rồi*"

📌 Ví dụ 4: Gọi API không đủ quyền

PUT `/api/jobs/1/approve` — Gọi bằng token Candidate

```
HTTP 403 Forbidden
```

> ✅ Hệ thống phân quyền hoạt động đúng — Endpoint `/approve` chỉ Admin mới gọi được.

7. Chạy dự án & Tài khoản demo

🚀 Khởi động Backend

```
# Yêu cầu: .NET 8 SDK, SQL Server
cd DevJobsAPI
dotnet run

# API chạy tại:   http://localhost:5050
# Swagger UI tại:  http://localhost:5050/swagger
```

🧪 Tài khoản demo (mật khẩu: 123456)

ROLE	EMAIL	TRANG SAU ĐĂNG NHẬP
Ứng viên	candidate@devjobs.vn	/jobs — Trang tìm việc
Nhà tuyển dụng	recruiter@devjobs.vn	/recruiter/jobs — Quản lý tin
Admin	admin@devjobs.vn	/admin/dashboard — Thống kê

📖 Hướng dẫn test API trên Swagger

1. Mở `http://localhost:5050/swagger`
2. Vào **POST /api/auth/login** → Try it out → Điền email/password → Execute
3. Copy chuỗi `token` từ Response
4. Bấm nút 🔒 **Authorize** (góc trên phải) → Paste token → Authorize
5. Gọi bất kỳ API nào — token sẽ tự động đính kèm vào header

DevJobs Backend API — Báo cáo tự động tạo từ dự án ASP.NET Core 8.0 · 2026